

TRƯỜNG ĐẠI HỌC BÁCH KHOA HÀ NỘI
VIỆN CÔNG NGHỆ THÔNG TIN VÀ TRUYỀN THÔNG

TIỂU LUẬN MÔN HỌC
NHẬP MÔN AN TOÀN THÔNG TIN

Điện toán đám mây và bảo mật điện toán đám mây

Phân tích rủi ro, lỗ hổng và các cơ chế bảo vệ dữ liệu

Nhóm thực hiện: Đào Trường Anh - 20235639
Nguyễn Đồng Minh Anh - 20235646
Đoàn Đình Bằng - 20235662

Giảng viên:

Hà Nội, 2026

Mục lục

1	Mở đầu	1
1.1	Lý do chọn đề tài	1
1.2	Mục tiêu nghiên cứu	1
1.3	Phạm vi nghiên cứu	2
1.4	Phương pháp nghiên cứu	2
1.5	Bố cục báo cáo	2
2	Tổng quan về điện toán đám mây	3
2.1	Khái niệm điện toán đám mây	3
2.2	Các mô hình dịch vụ	3
2.2.1	IaaS	3
2.2.2	PaaS	3
2.2.3	SaaS	3
2.3	Các mô hình triển khai	4
2.4	Shared Responsibility Model	4
2.5	Vai trò của cloud trong doanh nghiệp	4
3	Các nguy cơ an toàn thông tin trên điện toán đám mây	5
3.1	Mô hình CIA	5
3.2	Rò rỉ dữ liệu	5
3.3	Cấu hình sai	5
3.4	API không an toàn	5
3.5	Quản lý định danh yếu kém	6
3.6	Mối đe dọa nội bộ	6
3.7	Lỗi hỏng công nghệ dùng chung	6
3.8	Tấn công từ chối dịch vụ	6

4	Các cơ chế bảo mật trên Cloud	7
4.1	Bảo vệ dữ liệu bằng mật mã học	7
4.2	Quản lý khóa và chứng thư số	7
4.3	Quản lý định danh và kiểm soát truy cập	7
4.4	Bảo mật mạng và ứng dụng	7
4.5	Giám sát và ứng phó sự cố	8
4.6	Các mô hình bảo mật hiện đại	8
5	Quản lý rủi ro và tuân thủ trong điện toán đám mây	9
5.1	Quy trình quản lý rủi ro	9
5.2	Các tiêu chuẩn và khung tham chiếu	9
5.3	Bảo vệ dữ liệu cá nhân và yêu cầu pháp lý	9
5.4	Các chỉ số đánh giá hiệu quả bảo mật	10
6	Nghiên cứu tình huống: Cloud Security Demo	11
6.1	Mô tả bài toán	11
6.2	Kiến trúc hệ thống đề xuất	11
6.3	Tài sản cần bảo vệ	12
6.4	Phân tích mối đe dọa theo STRIDE	13
6.5	Kịch bản 1: Public Storage Bucket	14
6.6	Kịch bản 2: IAM Misconfiguration	14
6.7	Kịch bản 3: Credential Leakage	15
6.8	Biện pháp khắc phục	16
6.9	Đánh giá kết quả	19
7	Kết luận và hướng phát triển	20
7.1	Tổng kết kết quả nghiên cứu	20
7.2	Khuyến nghị cho doanh nghiệp	20
7.3	Hạn chế của nghiên cứu	20
7.4	Hướng phát triển	21
A	Phụ lục	23
A.1	Tài khoản và địa chỉ demo	23
A.2	Một số lệnh kiểm thử	23

Danh sách hình vẽ

6.1	Kiến trúc hệ thống Cloud Security Demo	11
6.2	Các container của môi trường demo đang hoạt động	12
6.3	Dữ liệu khách hàng được đọc từ PostgreSQL	12
6.4	Bucket public-customer-data trên MinIO Console	13
6.5	Bucket công khai trong chế độ vulnerable	14
6.6	Truy cập trực tiếp object customers.csv không cần xác thực	14
6.7	Tài khoản alice truy cập được trang admin trong chế độ vulnerable	15
6.8	Credential được hiển thị ở dạng rõ trong chế độ vulnerable	15
6.9	Cấu hình trước khi khắc phục: APP_MODE=vulnerable, SECRET_MODE=plaintext	16
6.10	Cấu hình sau khi khắc phục: APP_MODE=fixed, SECRET_MODE=encrypted . .	17
6.11	Tài khoản alice bị chặn khỏi trang admin sau khi khắc phục	17
6.12	Truy cập trực tiếp object bị từ chối sau khi bucket chuyển sang private	18
6.13	Secret được tách riêng và mã hóa trong chế độ fixed	18

Danh sách bảng

2.1	So sánh các mô hình dịch vụ cloud	4
5.1	Ví dụ ma trận đánh giá rủi ro	9
6.1	Phân tích mối đe dọa theo STRIDE trong case study	13
6.2	So sánh trạng thái hệ thống trước và sau khi áp dụng biện pháp bảo mật	19

Chương 1. Mở đầu

1.1 Lý do chọn đề tài

Điện toán đám mây đã trở thành nền tảng quan trọng trong quá trình chuyển đổi số của doanh nghiệp, trường học và các tổ chức nhà nước. Thay vì đầu tư toàn bộ hạ tầng vật lý, tổ chức có thể thuê máy chủ, lưu trữ, cơ sở dữ liệu và dịch vụ bảo mật thông qua Internet. Mô hình này giúp triển khai nhanh, mở rộng linh hoạt và tối ưu chi phí vận hành.

Tuy nhiên, môi trường đám mây cũng tạo ra nhiều rủi ro an toàn thông tin. Dữ liệu có thể bị rò rỉ do bucket lưu trữ công khai, tài khoản bị cấp quyền quá mức, API thiếu kiểm soát, secret bị đặt trực tiếp trong cấu hình hoặc hệ thống thiếu giám sát. Các sự cố này thường không xuất phát từ lỗi của nhà cung cấp dịch vụ, mà đến từ việc người dùng cấu hình sai hoặc chưa hiểu rõ mô hình chia sẻ trách nhiệm.

Vì vậy, đề tài “Điện toán đám mây và bảo mật điện toán đám mây” được thực hiện nhằm hệ thống hóa kiến thức nền tảng, phân tích các rủi ro phổ biến và xây dựng một mô hình demo nhỏ để minh họa quá trình phát hiện và khắc phục lỗi bảo mật trong môi trường cloud.

1.2 Mục tiêu nghiên cứu

Đề tài hướng đến các mục tiêu chính sau:

- Trình bày khái niệm, đặc trưng, mô hình dịch vụ và mô hình triển khai của điện toán đám mây.
- Phân tích các rủi ro an toàn thông tin thường gặp trên cloud, đặc biệt là rò rỉ dữ liệu, cấu hình sai, quản lý danh yếu và lộ thông tin nhạy cảm.
- Trình bày các cơ chế bảo vệ như mã hóa, quản lý khóa, IAM, MFA, WAF, logging, monitoring và Zero Trust.
- Xây dựng case study với Flask, PostgreSQL, MinIO và Docker Compose để minh họa ba lỗi bảo mật: public storage bucket, IAM misconfiguration và credential leakage.
- Đề xuất khuyến nghị giúp vận hành hệ thống cloud an toàn hơn.

1.3 Phạm vi nghiên cứu

Báo cáo tập trung vào các nguyên lý và rủi ro phổ biến trong môi trường cloud ở mức nhập môn. Phần thực nghiệm sử dụng mô hình local bằng Docker để giả lập một hệ thống cloud nhỏ, gồm web application, cơ sở dữ liệu và object storage. Báo cáo không đi sâu vào triển khai production trên một nền tảng cụ thể như AWS, Microsoft Azure hoặc Google Cloud Platform.

1.4 Phương pháp nghiên cứu

Nhóm sử dụng bốn phương pháp chính:

- **Nghiên cứu tài liệu:** tổng hợp kiến thức từ tài liệu chuẩn như NIST, CSA, ISO/IEC và OWASP.
- **Phân tích và tổng hợp:** phân loại các nguy cơ theo nhóm rủi ro và cơ chế phòng thủ tương ứng.
- **So sánh đánh giá:** đối chiếu trạng thái trước và sau khi áp dụng biện pháp bảo mật.
- **Nghiên cứu tình huống:** xây dựng demo để quan sát tác động của lỗi cấu hình và cách khắc phục.

1.5 Bố cục báo cáo

Báo cáo gồm bảy chương. Chương 1 giới thiệu đề tài. Chương 2 trình bày tổng quan điện toán đám mây. Chương 3 phân tích các nguy cơ an toàn thông tin. Chương 4 trình bày các cơ chế bảo mật. Chương 5 nói về quản lý rủi ro và tuân thủ. Chương 6 là case study thực nghiệm. Chương 7 tổng kết và nêu hướng phát triển.

Chương 2. Tổng quan về điện toán đám mây

2.1 Khái niệm điện toán đám mây

Điện toán đám mây là mô hình cung cấp tài nguyên công nghệ thông tin theo nhu cầu thông qua mạng Internet. Các tài nguyên này có thể bao gồm máy chủ, lưu trữ, cơ sở dữ liệu, mạng, nền tảng phát triển phần mềm và ứng dụng hoàn chỉnh. Người dùng không cần trực tiếp quản lý hạ tầng vật lý mà có thể thuê và sử dụng theo mức tiêu thụ thực tế.

Theo NIST, điện toán đám mây có năm đặc trưng cơ bản: tự phục vụ theo nhu cầu, truy cập rộng qua mạng, gộp tài nguyên, co giãn nhanh và đo lường dịch vụ. Các đặc trưng này giúp cloud trở thành nền tảng phù hợp cho hệ thống cần mở rộng nhanh, triển khai linh hoạt và tối ưu chi phí.

2.2 Các mô hình dịch vụ

2.2.1 IaaS

IaaS cung cấp hạ tầng như máy chủ ảo, ổ đĩa, mạng và firewall. Khách hàng kiểm soát hệ điều hành, ứng dụng và dữ liệu. Mô hình này linh hoạt nhưng yêu cầu người dùng có năng lực quản trị hệ thống.

2.2.2 PaaS

PaaS cung cấp môi trường chạy ứng dụng, middleware và công cụ phát triển. Nhà cung cấp quản lý phần lớn hạ tầng, còn người dùng tập trung vào mã nguồn và dữ liệu ứng dụng.

2.2.3 SaaS

SaaS cung cấp phần mềm hoàn chỉnh qua Internet. Người dùng chỉ sử dụng ứng dụng mà không cần quản trị hạ tầng hoặc nền tảng bên dưới.

Bảng 2.1: So sánh các mô hình dịch vụ cloud

Tiêu chí	IaaS	PaaS	SaaS
Mức kiểm soát	Cao	Trung bình	Thấp
Đối tượng chính	Quản trị hệ thống	Lập trình viên	Người dùng cuối
Khách hàng quản lý	OS, app, dữ liệu	App, dữ liệu	Cấu hình sử dụng
Ví dụ	VM, storage, network	App platform	Email, office suite

2.3 Các mô hình triển khai

Public Cloud là mô hình cloud do nhà cung cấp bên thứ ba vận hành, nhiều khách hàng cùng sử dụng hạ tầng chung. **Private Cloud** phục vụ riêng một tổ chức, có mức kiểm soát cao hơn nhưng chi phí lớn hơn. **Hybrid Cloud** kết hợp public và private cloud. **Multi-Cloud** sử dụng nhiều nhà cung cấp cloud để giảm phụ thuộc và tăng tính linh hoạt.

2.4 Shared Responsibility Model

Mô hình chia sẻ trách nhiệm là nguyên tắc quan trọng trong bảo mật cloud. Nhà cung cấp chịu trách nhiệm bảo vệ hạ tầng bên dưới, còn khách hàng chịu trách nhiệm bảo vệ dữ liệu, tài khoản, cấu hình dịch vụ và ứng dụng của mình. Rất nhiều sự cố cloud xảy ra khi khách hàng hiểu sai ranh giới trách nhiệm này.

2.5 Vai trò của cloud trong doanh nghiệp

Cloud giúp doanh nghiệp triển khai sản phẩm nhanh hơn, mở rộng hệ thống theo lưu lượng thực tế, tối ưu chi phí ban đầu và tiếp cận các dịch vụ bảo mật hiện đại. Tuy nhiên, lợi ích này chỉ đạt được khi hệ thống được thiết kế và vận hành với tư duy bảo mật ngay từ đầu.

Chương 3. Các nguy cơ an toàn thông tin trên điện toán đám mây

3.1 Mô hình CIA

Ba mục tiêu cơ bản của an toàn thông tin là bảo mật, toàn vẹn và sẵn sàng. Trong môi trường cloud, dữ liệu cần được bảo vệ khỏi truy cập trái phép, không bị thay đổi ngoài ý muốn và luôn sẵn sàng khi người dùng hợp lệ cần sử dụng.

3.2 Rò rỉ dữ liệu

Rò rỉ dữ liệu có thể xảy ra khi dữ liệu nhạy cảm được lưu trong bucket công khai, database mở cổng ra Internet, secret bị commit lên repository hoặc API trả về quá nhiều thông tin. Đây là một trong những rủi ro nghiêm trọng nhất vì ảnh hưởng trực tiếp đến khách hàng, uy tín và trách nhiệm pháp lý của tổ chức.

3.3 Cấu hình sai

Cấu hình sai là nguyên nhân phổ biến của sự cố cloud. Ví dụ: object storage public, security group mở toàn bộ cổng, IAM policy cấp quyền quá rộng, logging bị tắt hoặc khóa mã hóa không được xoay vòng. Điểm nguy hiểm là lỗi cấu hình thường rất nhỏ nhưng có thể tạo ra hậu quả lớn.

3.4 API không an toàn

Cloud service và web application thường giao tiếp qua API. Nếu API thiếu xác thực, thiếu phân quyền, không kiểm tra input hoặc không giới hạn tốc độ, attacker có thể khai thác để đọc dữ liệu, sửa dữ liệu hoặc gây quá tải hệ thống.

3.5 Quản lý định danh yếu kém

Tài khoản cloud thường có quyền truy cập nhiều tài nguyên quan trọng. Nếu không bật MFA, dùng mật khẩu yếu hoặc cấp quyền vượt nhu cầu, attacker có thể chiếm tài khoản và mở rộng quyền truy cập trong hệ thống.

3.6 Mối đe dọa nội bộ

Insider threat đến từ nhân viên, nhà thầu hoặc tài khoản nội bộ bị chiếm quyền. Trong cloud, insider có thể sao chép dữ liệu, thay đổi cấu hình, xóa log hoặc tạo backdoor nếu quyền truy cập không được giới hạn và giám sát.

3.7 Lỗi hỏng công nghệ dùng chung

Cloud dựa trên ảo hóa, container, hypervisor và hạ tầng dùng chung. Nếu có lỗi ở lớp nền tảng hoặc cấu hình cô lập tenant không đúng, rủi ro có thể lan rộng giữa các môi trường khác nhau.

3.8 Tấn công từ chối dịch vụ

DDoS làm cạn tài nguyên mạng, CPU, memory hoặc quota dịch vụ. Dù cloud có khả năng mở rộng, hệ thống vẫn cần rate limiting, autoscaling hợp lý, CDN, WAF và cơ chế cảnh báo để giảm tác động.

Chương 4. Các cơ chế bảo mật trên Cloud

4.1 Bảo vệ dữ liệu bằng mật mã học

Dữ liệu cần được mã hóa khi lưu trữ và khi truyền tải. Mã hóa dữ liệu lưu trữ giúp giảm thiểu tác động nếu thiết bị lưu trữ hoặc bản sao dữ liệu bị truy cập trái phép. Mã hóa dữ liệu truyền tải, thường thông qua TLS, giúp bảo vệ dữ liệu khỏi nghe lén và chỉnh sửa trên đường truyền.

4.2 Quản lý khóa và chứng thư số

Mã hóa chỉ hiệu quả khi khóa được quản lý an toàn. KMS hỗ trợ tạo, lưu trữ, phân quyền và xoay vòng khóa. HSM cung cấp môi trường phần cứng an toàn hơn cho khóa quan trọng. PKI và Certificate Authority giúp xác thực danh tính dịch vụ và thiết lập kết nối tin cậy.

4.3 Quản lý định danh và kiểm soát truy cập

IAM là lớp bảo vệ trung tâm trong cloud. Các nguyên tắc quan trọng gồm:

- bật MFA cho tài khoản quan trọng;
- áp dụng least privilege;
- phân quyền theo vai trò bằng RBAC;
- tách tài khoản quản trị và tài khoản sử dụng thường ngày;
- định kỳ rà soát quyền truy cập.

4.4 Bảo mật mạng và ứng dụng

Bảo mật mạng cloud bao gồm phân vùng mạng, firewall, security group, private subnet và kiểm soát truy cập vào dịch vụ nội bộ. Với web application, WAF giúp phát hiện và chặn các mẫu tấn công phổ biến như SQL Injection, XSS, path traversal hoặc request bất thường.

4.5 Giám sát và ứng phó sự cố

Logging và audit trail giúp truy vết hành vi người dùng và dịch vụ. IDS/IPS, SIEM và hệ thống cảnh báo giúp phát hiện sự kiện bất thường. Quy trình incident response giúp tổ chức phản ứng có thứ tự khi xảy ra sự cố, bao gồm phát hiện, cô lập, xử lý, khôi phục và rút kinh nghiệm.

4.6 Các mô hình bảo mật hiện đại

Zero Trust đặt giả định rằng không có thành phần nào mặc nhiên đáng tin cậy. Mọi request đều cần được xác thực, phân quyền và đánh giá ngữ cảnh. Defense in Depth triển khai nhiều lớp bảo vệ để khi một lớp thất bại, các lớp khác vẫn giảm thiểu tác động. Security by Design yêu cầu bảo mật được đưa vào từ giai đoạn thiết kế, không chỉ bổ sung sau khi hệ thống đã hoàn thành.

Chương 5. Quản lý rủi ro và tuân thủ trong điện toán đám mây

5.1 Quy trình quản lý rủi ro

Quản lý rủi ro bắt đầu bằng việc xác định tài sản cần bảo vệ, chẳng hạn dữ liệu khách hàng, tài khoản quản trị, khóa truy cập, database và log hệ thống. Sau đó, nhóm cần xác định mối đe dọa, đánh giá khả năng xảy ra và mức độ tác động, rồi lựa chọn biện pháp giảm thiểu phù hợp.

Bảng 5.1: Ví dụ ma trận đánh giá rủi ro

Rủi ro	Khả năng	Tác động	Biện pháp giảm thiểu
Bucket public làm lộ dữ liệu	Cao	Cao	Private bucket, signed URL, audit policy
User thường có quyền admin	Trung bình	Cao	RBAC, least privilege, review quyền
Secret nằm trong cấu hình rõ	Cao	Cao	Secret manager, mã hóa, tách khỏi source code

5.2 Các tiêu chuẩn và khung tham chiếu

Một số khung tham chiếu thường dùng trong bảo mật cloud gồm NIST Cybersecurity Framework, CSA Cloud Controls Matrix, ISO/IEC 27001, ISO/IEC 27017 và ISO/IEC 27018. Các tài liệu này giúp tổ chức xây dựng chính sách, kiểm soát rủi ro và chứng minh mức độ tuân thủ.

5.3 Bảo vệ dữ liệu cá nhân và yêu cầu pháp lý

Dữ liệu cá nhân cần được xử lý theo nguyên tắc tối thiểu hóa, có mục đích rõ ràng, được bảo vệ bằng biện pháp kỹ thuật phù hợp và có khả năng truy vết. Khi xảy ra rò rỉ dữ liệu, tổ chức có thể phải thông báo sự cố, khắc phục hậu quả và chịu trách nhiệm pháp lý.

5.4 Các chỉ số đánh giá hiệu quả bảo mật

Một số chỉ số có thể dùng để đánh giá hiệu quả bảo mật:

- **MTTD:** thời gian trung bình để phát hiện sự cố.
- **MTTR:** thời gian trung bình để phản ứng hoặc khôi phục.
- **MFA Adoption Rate:** tỷ lệ tài khoản đã bật MFA.
- **Encryption Coverage Rate:** tỷ lệ dữ liệu đã được mã hóa.

Chương 6. Nghiên cứu tình huống: Cloud Security Demo

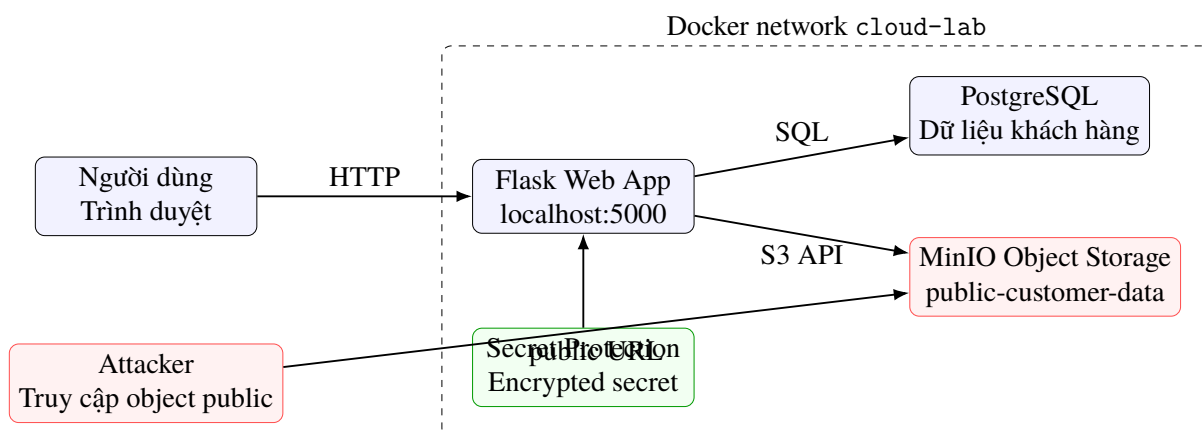
6.1 Mô tả bài toán

Nhóm xây dựng một hệ thống demo nhỏ để mô phỏng các lỗi bảo mật thường gặp trong môi trường cloud. Hệ thống gồm web application viết bằng Flask, cơ sở dữ liệu PostgreSQL và dịch vụ object storage MinIO. Toàn bộ môi trường chạy bằng Docker Compose để dễ triển khai, tái hiện và trình bày.

Mục tiêu của case study là minh họa ba rủi ro chính:

- **Public Storage Bucket:** bucket lưu trữ dữ liệu khách hàng bị cấu hình công khai.
- **IAM Misconfiguration:** tài khoản người dùng thường bị cấp nhầm quyền quản trị.
- **Credential Leakage:** secret và credential được đặt trực tiếp trong cấu hình ở dạng rõ.

6.2 Kiến trúc hệ thống đề xuất

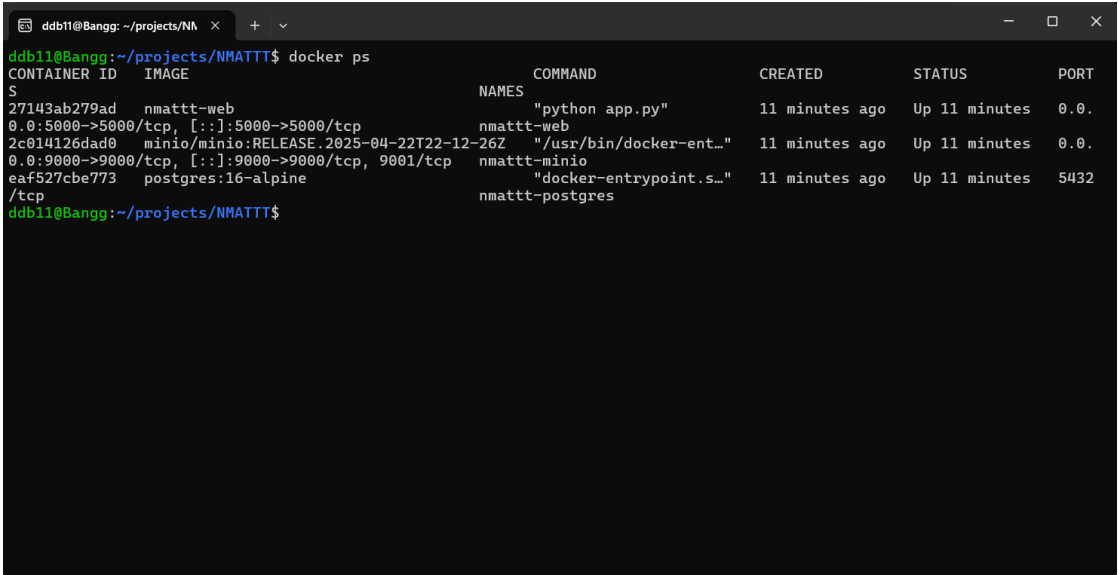


Hình 6.1: Kiến trúc hệ thống Cloud Security Demo

Các thành phần chính gồm:

- **Flask Web App:** cung cấp giao diện đăng nhập, xem dữ liệu khách hàng, truy cập storage, trang admin và trang minh họa rủi ro cấu hình.

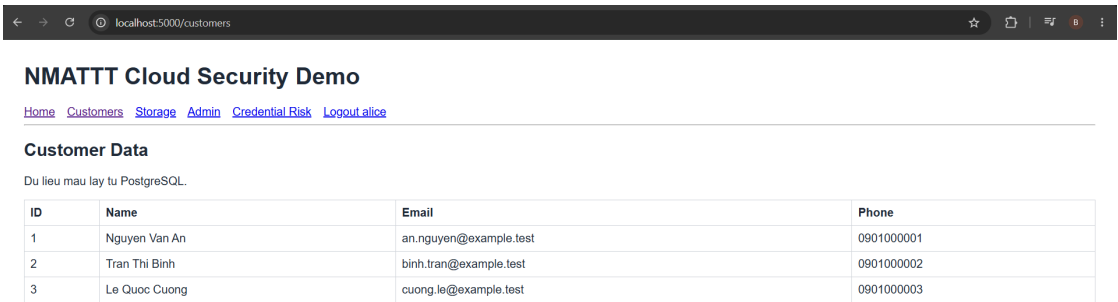
- **PostgreSQL:** lưu dữ liệu khách hàng và audit log mẫu.
- **MinIO:** giả lập dịch vụ object storage tương tự Amazon S3.
- **Docker Compose:** khởi chạy toàn bộ môi trường thực nghiệm.



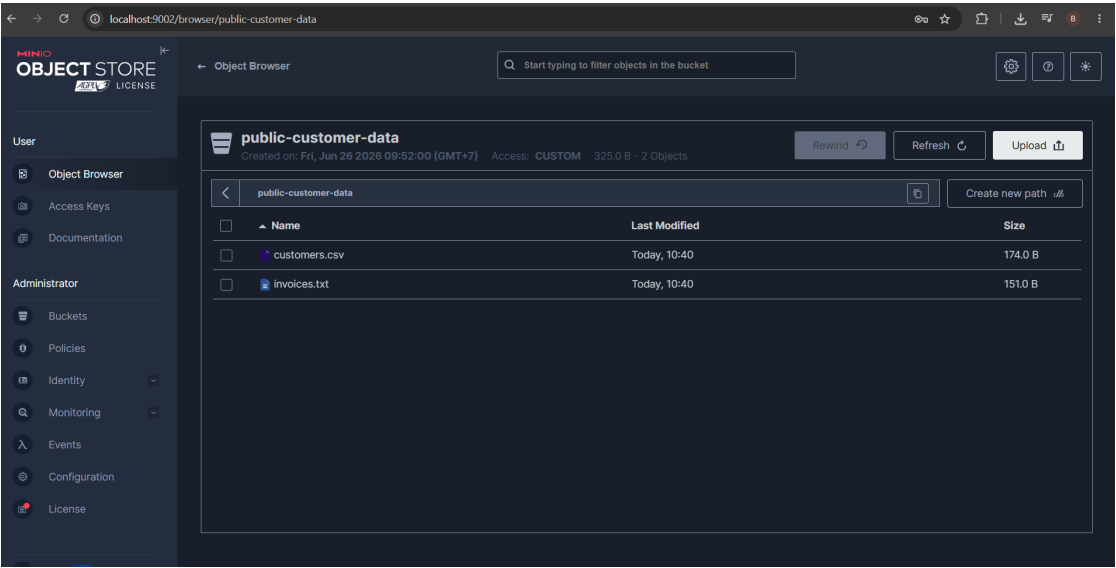
Hình 6.2: Các container của môi trường demo đang hoạt động

6.3 Tài sản cần bảo vệ

Trong mô hình demo, tài sản quan trọng gồm dữ liệu khách hàng trong PostgreSQL, file dữ liệu trong bucket MinIO, tài khoản quản trị, thông tin truy cập database và access key của MinIO.



Hình 6.3: Dữ liệu khách hàng được đọc từ PostgreSQL



Hình 6.4: Bucket public-customer-data trên MinIO Console

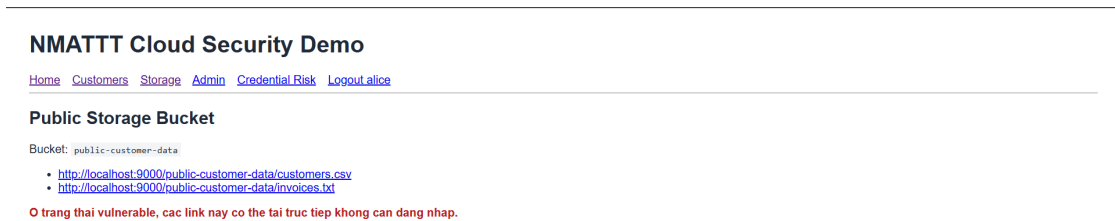
6.4 Phân tích mối đe dọa theo STRIDE

Bảng 6.1: Phân tích mối đe dọa theo STRIDE trong case study

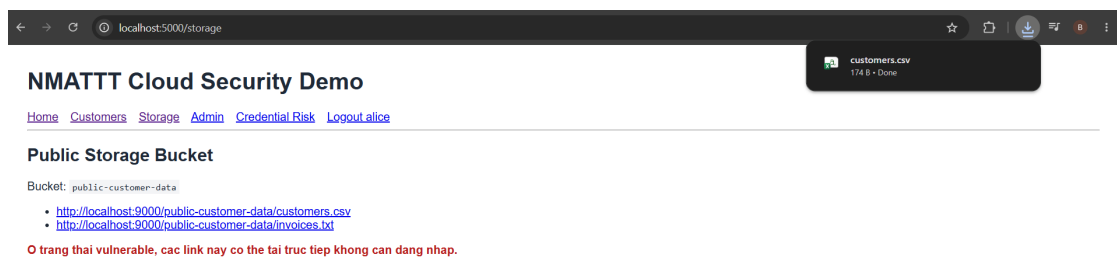
Nhóm STRIDE	Mối đe dọa	Biện pháp giảm thiểu
Spoofing	Attacker sử dụng tài khoản yếu hoặc credential bị lộ để đăng nhập.	MFA, mật khẩu mạnh, giới hạn đăng nhập, tách tài khoản admin.
Tampering	Dữ liệu trong bucket hoặc database bị thay đổi trái phép.	Phân quyền ghi, checksum, audit log, versioning.
Repudiation	Người dùng phủ nhận hành động do thiếu log.	Audit trail, ghi log truy cập, đồng bộ thời gian.
Information Disclosure	Bucket public hoặc secret plaintext làm lộ dữ liệu.	Private bucket, signed URL, mã hóa secret, không commit credential.
Denial of Service	Request bất thường gây quá tải web app hoặc storage.	Rate limiting, WAF, giám sát tài nguyên, cảnh báo.
Elevation of Privilege	User thường truy cập được trang admin.	RBAC, least privilege, kiểm tra quyền ở server side.

6.5 Kịch bản 1: Public Storage Bucket

Ở chế độ vulnerable, web app hiển thị đường dẫn đến object trong bucket. Do bucket được cấu hình công khai, người dùng có thể mở trực tiếp file dữ liệu mà không cần xác thực.



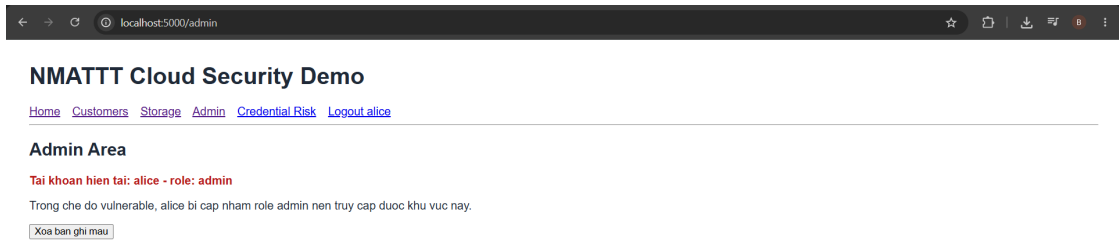
Hình 6.5: Bucket công khai trong chế độ vulnerable



Hình 6.6: Truy cập trực tiếp object customers.csv không cần xác thực

6.6 Kịch bản 2: IAM Misconfiguration

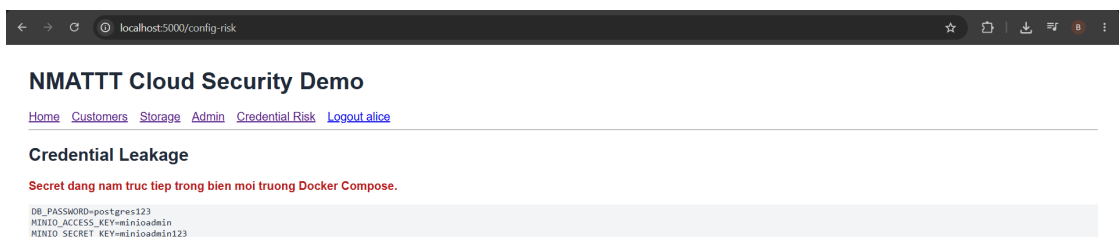
Tài khoản alice là người dùng thường, nhưng ở chế độ vulnerable tài khoản này vẫn truy cập được trang /admin. Đây là ví dụ điển hình của lỗi phân quyền server side.



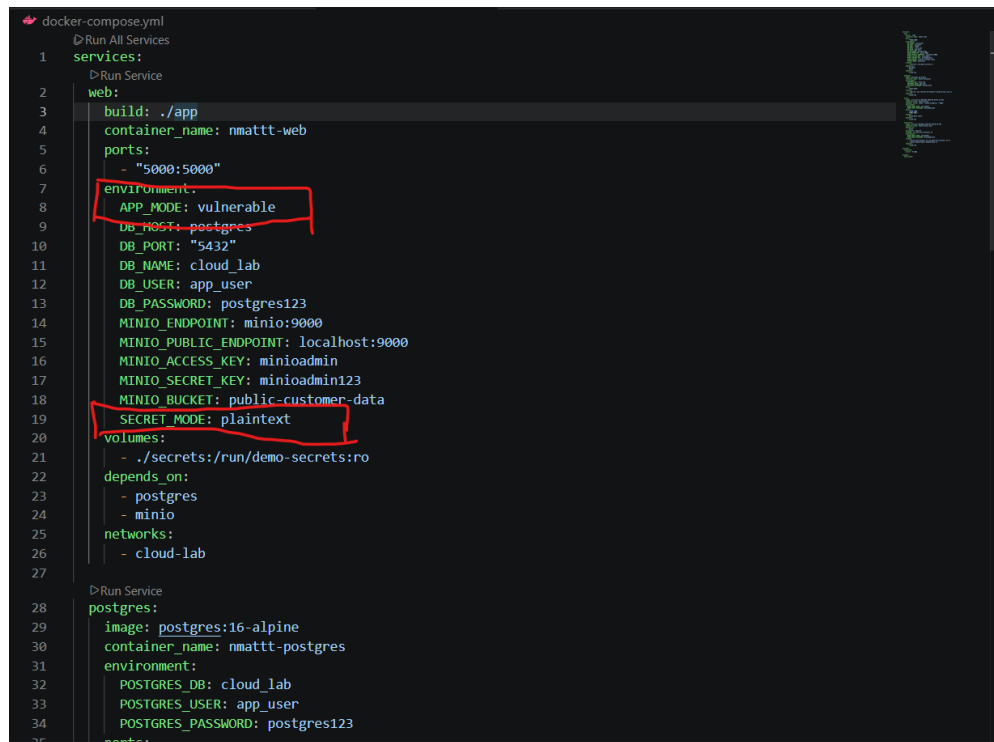
Hình 6.7: Tài khoản alice truy cập được trang admin trong chế độ vulnerable

6.7 Kịch bản 3: Credential Leakage

Ở chế độ plaintext, thông tin nhạy cảm như mật khẩu database và MinIO secret key xuất hiện trong cấu hình. Nếu repository hoặc file cấu hình bị lộ, attacker có thể dùng các secret này để truy cập dịch vụ nội bộ.



Hình 6.8: Credential được hiển thị ở dạng rõ trong chế độ vulnerable



Hình 6.9: Cấu hình trước khi khắc phục: APP_MODE=vulnerable, SECRET_MODE=plaintext

6.8 Biện pháp khắc phục

Nhóm chuyển hệ thống sang chế độ fixed. Các thay đổi chính gồm:

- chuyển bucket từ public sang private;
- kiểm tra quyền truy cập trang admin theo vai trò;
- tách secret khỏi mã nguồn và lưu dưới dạng mã hóa;
- chỉ giải mã secret trong runtime khi ứng dụng cần sử dụng.

```

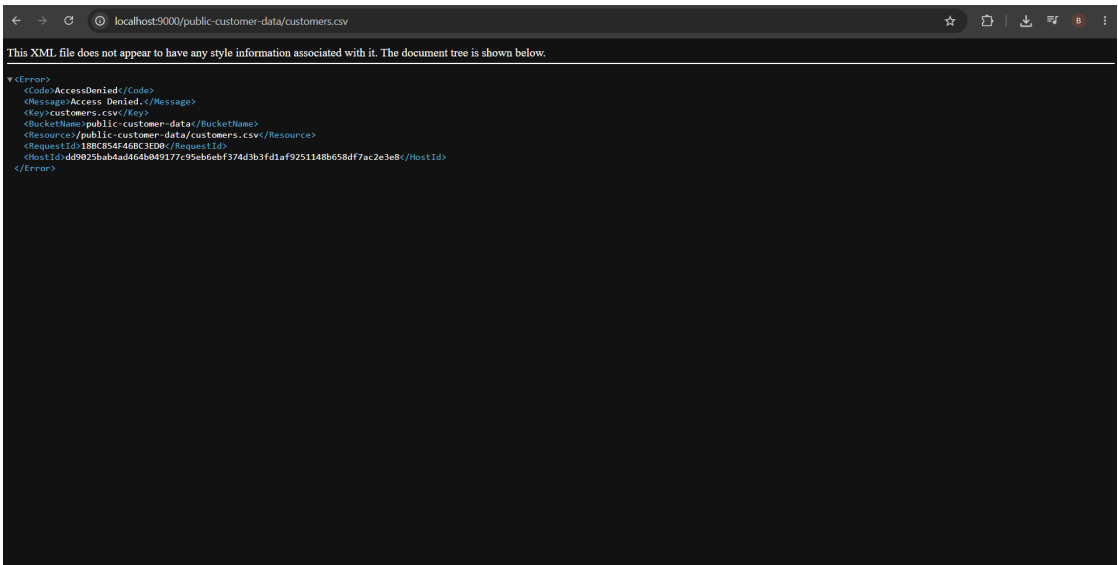
1  services:
2    web:
3      build: ./app
4      container_name: nmattt-web
5      ports:
6        - "5000:5000"
7      environment:
8        APP_MODE: fixed
9        DB_HOST: postgres
10       DB_PORT: "5432"
11       DB_NAME: cloud_lab
12       DB_USER: app_user
13       DB_PASSWORD: postgres123
14       MINIO_ENDPOINT: minio:9000
15       MINIO_PUBLIC_ENDPOINT: localhost:9000
16       MINIO_ACCESS_KEY: minioadmin
17       MINIO_SECRET_KEY: minioadmin123
18       MINIO_BUCKET: public-customer-data
19       SECRET_MODE: encrypted
20     volumes:
21       - ./secrets:/run/demo-secrets:ro
22     depends_on:
23       - postgres
24       - minio
25     networks:
26       - cloud-lab
27
28  postgres:
29    image: postgres:16-alpine
30    container_name: nmattt-postgres
31    environment:
32      POSTGRES_DB: cloud_lab
33      POSTGRES_USER: app_user
34      POSTGRES_PASSWORD: postgres123

```

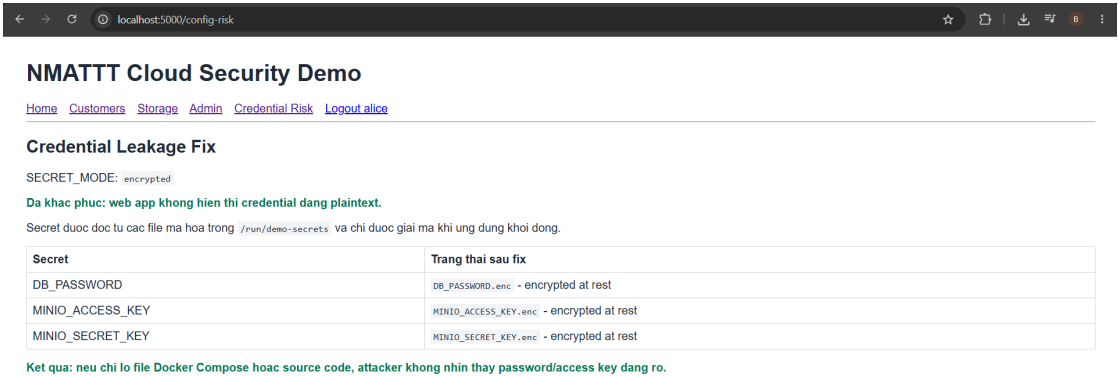
Hình 6.10: Cấu hình sau khi khắc phục: APP_MODE=fixed, SECRET_MODE=encrypted



Hình 6.11: Tài khoản alice bị chặn khỏi trang admin sau khi khắc phục



Hình 6.12: Truy cập trực tiếp object bị từ chối sau khi bucket chuyển sang private



Hình 6.13: Secret được tách riêng và mã hóa trong chế độ fixed

Bảng 6.2: So sánh trạng thái hệ thống trước và sau khi áp dụng biện pháp bảo mật

Nội dung đánh giá	Trước khi khắc phục	Sau khi khắc phục
Public Storage Bucket	Bucket <code>public-customer-data</code> được cấu hình công khai. Người dùng có thể mở trực tiếp đường dẫn object như <code>customers.csv</code> mà không cần xác thực.	Bucket được chuyển sang chế độ riêng tư. Khi truy cập trực tiếp object, hệ thống từ chối yêu cầu hoặc yêu cầu thông tin xác thực hợp lệ.
IAM Misconfiguration	Tài khoản người dùng thường <code>alice</code> bị cấp nhầm quyền quản trị và có thể truy cập trang <code>/admin</code> .	Quyền truy cập được kiểm tra theo vai trò. Tài khoản <code>alice</code> không còn truy cập được trang quản trị.
Credential Leakage	Thông tin nhạy cảm như mật khẩu cơ sở dữ liệu, <code>access key</code> và <code>secret key</code> được đặt trực tiếp trong cấu hình ở dạng rõ.	<code>Secret</code> được tách khỏi mã nguồn và lưu dưới dạng đã mã hóa. Ứng dụng chỉ giải mã khi cần sử dụng trong môi trường runtime.
Khả năng giám sát	Việc phát hiện truy cập bất thường còn phụ thuộc vào quan sát thủ công trong quá trình demo.	Hệ thống có thể mở rộng bằng <code>audit log</code> , cảnh báo truy cập trái phép và theo dõi các chỉ số như <code>MTTD</code> , <code>MTTR</code> .
Tác động bảo mật	Dữ liệu khách hàng và thông tin cấu hình có nguy cơ bị lộ nếu <code>attacker</code> truy cập được <code>endpoint</code> hoặc <code>repository</code> .	Giảm nguy cơ rò rỉ dữ liệu, giới hạn quyền theo nguyên tắc <code>least privilege</code> và giảm thiểu tác động khi cấu hình bị lộ.

6.9 Đánh giá kết quả

Kết quả thực nghiệm cho thấy các lỗi cấu hình cloud có thể được tái hiện rõ ràng ngay trong một môi trường nhỏ. Khi bucket public, dữ liệu có thể bị đọc trực tiếp qua URL. Khi phân quyền sai, user thường có thể truy cập chức năng quản trị. Khi secret nằm ở dạng rõ, rủi ro lộ credential tăng đáng kể.

Sau khi khắc phục, các hành vi truy cập trái phép bị chặn, dữ liệu storage không còn public và secret được bảo vệ tốt hơn. Mô hình demo chưa thay thế cho hệ thống production, nhưng đủ để minh họa nguyên tắc quan trọng: bảo mật cloud phụ thuộc rất lớn vào cấu hình, phân quyền và quản lý secret của người vận hành.

Chương 7. Kết luận và hướng phát triển

7.1 Tổng kết kết quả nghiên cứu

Báo cáo đã trình bày tổng quan về điện toán đám mây, các mô hình dịch vụ, mô hình triển khai và mô hình chia sẻ trách nhiệm. Trên cơ sở đó, báo cáo phân tích các rủi ro an toàn thông tin phổ biến như rò rỉ dữ liệu, cấu hình sai, API không an toàn, quản lý định danh yếu và lộ credential.

Phần case study đã xây dựng một môi trường demo bằng Flask, PostgreSQL, MinIO và Docker Compose. Mô hình này minh họa ba lỗi thường gặp trong thực tế: public storage bucket, IAM misconfiguration và credential leakage. Kết quả trước và sau khi khắc phục cho thấy các biện pháp như private bucket, RBAC, least privilege và mã hóa secret có thể giảm đáng kể rủi ro.

7.2 Khuyến nghị cho doanh nghiệp

Khi triển khai hệ thống trên cloud, doanh nghiệp nên:

- áp dụng least privilege cho toàn bộ tài khoản và service account;
- bật MFA cho tài khoản có quyền cao;
- mặc định đặt object storage ở chế độ private;
- không lưu secret trực tiếp trong mã nguồn hoặc file cấu hình public;
- bật logging, audit trail và cảnh báo truy cập bất thường;
- định kỳ rà soát cấu hình cloud theo checklist bảo mật.

7.3 Hạn chế của nghiên cứu

Mô hình thực nghiệm được triển khai trong môi trường local bằng Docker, chưa phản ánh đầy đủ các yếu tố của hệ thống production như high availability, autoscaling, network segmentation phức tạp, quản lý danh tính tập trung hoặc tích hợp SIEM thực tế. Ngoài ra, demo mới tập trung vào ba lỗi bảo mật tiêu biểu, chưa bao phủ toàn bộ rủi ro cloud.

7.4 Hướng phát triển

Trong tương lai, đề tài có thể được mở rộng theo các hướng sau:

- triển khai demo trên một nền tảng cloud thật như AWS, Azure hoặc Google Cloud;
- bổ sung WAF, rate limiting và giám sát log tập trung;
- tích hợp alert cho các hành vi như truy cập object bị từ chối hoặc đăng nhập admin thất bại;
- mở rộng demo sang container security và Kubernetes security;
- đánh giá thêm các mô hình như Zero Trust và Confidential Computing.

Tài liệu tham khảo

- [1] Cloud Security Alliance. Security guidance for critical areas of focus in cloud computing, 2021.
- [2] International Organization for Standardization. Iso/iec 27001 information security management, 2022.
- [3] National Institute of Standards and Technology. Guidelines on security and privacy in public cloud computing, 2011. Special Publication 800-144.
- [4] National Institute of Standards and Technology. The nist definition of cloud computing, 2011. Special Publication 800-145.
- [5] OWASP Foundation. Owasp api security top 10, 2023.

Chương A. Phụ lục

A.1 Tài khoản và địa chỉ demo

- Web app: <http://localhost:5000>
- MinIO Console: <http://localhost:9001>
- MinIO API: <http://localhost:9000>
- Tài khoản web: admin/admin123, alice/user123
- Tài khoản MinIO: minioadmin/minioadmin123

A.2 Một số lệnh kiểm thử

```
docker compose up --build
docker compose ps
```